

HACKER WOMAN COUNCIL - ETHICAL HACKING

Programa de formación en Ciberseguridad.

INFORME DE PRUEBAS DE PENETRACIÓN DE SEGURIDAD WEB — AURORA MARKET

ACTIVIDAD 01 – Análisis y planificación del pentest

Preparado por: Yorjana. A. Noriega. D (Equipo de Ethical Hacking)

Preparado para: Aurora Market

Fecha de Evaluación: 31/08/2026 al 01/09/2026

Clasificación de Seguridad: **RESTRINGIDO / CONFIDENCIAL**

Objetivos del pentest

1. Determinar qué tan expuesta está la aplicación web del comercio ante el manejo de información sensible y confidencial.
2. Identificar y comprender cómo este riesgo afectaría la integridad y reputación del comercio, teniendo repercusiones financieras y legales asociados al fallo descubierto.
3. Proporcionar un plan de contingencia (técnico y estratégico), medidas de solución que debe tomar el comercio para un mejor y más efectivo funcionamiento en la protección en la confianza de sus clientes.

Alcance de pentest

Se evalúa: aplicación web (únicamente), dentro de ello abarca: los clientes pueden crear cuentas/registros, iniciar sesión, buscar productos, agregar artículos al carrito, realizar compras y consultar compras relacionadas con sus pedidos, como también almacén información de la cliente desde nombres, correos electrónicos, teléfonos, direcciones de envío e historial de compras. Por otra parte, existe dentro de la aplicación el área del personal de la empresa para administrar productos, usuarios y pedidos.

Fuera del alcance: redes sociales, equipo personal (empleados), cuentas de correo, proveedores externos, ni otros sistemas fuera de lo acordado.

Autorización y condiciones

Permisos requeridos: Aurora Market proporcione autorización formal al equipo de Ethical Hacking, únicamente sobre la aplicación web.

Condiciones acordadas: no está permitido atacar las redes sociales de la empresa, los equipos personales de los empleados, sus cuentas de correo, proveedores externos y ningún tipo de sistema fuera del alcance, no realizar acciones que interrumpan deliberadamente la funcionalidad la plataforma y afecten la información real de los clientes, la evaluación debe implementarse durante horario de menos actividad para reducir al mínimo impacto y finalmente se solicita que cualquier problema encontrado sea documentado cuidadosamente.

Tipo de pentest

Elegido: Gray-box.

Justificación: poco conocimiento de la infraestructura (no entrego toda la información técnica), se conoce la existencia de la plataforma web, la base de datos, mecanismos de autenticación, diferencia de los tipos de usuario, pero carece de información detallada sobre la construcción y tecnología implementada en la aplicación. Su objetivo es descubrir las vulnerabilidades existentes (no se conoce con exactitud si existe una vulnerabilidad por eso se evalúa), aunque existe un reporte dirigido al área de atención al cliente.

Planificación pentest

- **Definir objetivo:** evaluar la seguridad de la aplicación web, identificando fallas lógicas del comercio y controles de acceso, como también determinar el origen del incidente notificado (visualización de datos de otra cuenta).
- **Determinar el alcance:** enfoque en la aplicación web del comercio electrónico de Aurora Market, donde nunca se había realizado una evaluación formal de seguridad.
- **Obtener permisos y condiciones:** validación y firma de autorización formal al equipo de Ethical Hacking únicamente sobre la aplicación web. No se permite ataques a redes sociales, equipo personal, correo, proveedores, realizar interrupción, ni

modificar datos dentro de la plataforma, realizar la prueba dentro de un horario menos activo/tráfico.

- **Selección de metodología:** se utilizará un enfoque de Caja Gris (Gray-Box) y aplicación del marco de trabajo OWASP Web Security Testing Guide (WSTG), alineación de hallazgos con el OWASP Top 10 (2025) junto con las fases del proceso con PTES.
- **Recopilación de información previa:** la información inicial suministrada por Aurora Market es limitada, reflejando un escenario donde la plataforma ha crecido rápido de forma comercial pero sin auditorías de seguridad previas. Se conoce la existencia de la aplicación web. El equipo asume evaluar y analizar el incidente reportado, implementar la fase de reconocimiento sin credenciales para identificar exposiciones que alberguen vulnerabilidades.
- **Recursos necesarios:**
 - ✓ Credenciales de prueba: cuentas asignadas por el cliente para representar los diferentes roles (mínimo una cuenta de "cliente A - de un cliente", una de "cliente B - área de administración")
 - ✓ Herramientas técnicas: proxies de interceptación local (OWASP ZAP) para el análisis manual del tráfico web y la manipulación de parámetros de la API
 - ✓ Reconocimiento activo (mapeo de rutas): enumeración manual de endpoints (/registro, /login, /carrito, /api/v1/customers/, /area-personal/)
 - ✓ Mapeo lógico: diagramación conceptual del flujo de información entre el navegador, la API de backend de Aurora y la base de datos centralizada de clientes.
- **Programación del pentest:** establecer un cronograma que defina los días de pruebas validos (bajo trafico autorizado para minimizar el impacto) y días posteriores analizar los datos y redacción del reporte. El esfuerzo técnico total estimado para el desarrollo de las pruebas lógicas es de 16 horas especializadas.

Fases del pentest

Reconocimiento: analizar de manera externa las cabeceras de respuesta HTTP y los certificados digitales expuestos a Internet para determinar el servidor web activo (como Apache o Nginx) y los frameworks de soporte, como también examinar archivos públicos en el sitio web para identificar si existen datos residuales que revelen nombres de usuarios, directorios del servidor o la existencia de un control de versiones expuesto.

Análisis de vulnerabilidades: analizar la página web, portales de clientes en busca de fallo en la aplicación, problemas de permisos, configuración incorrecta (que se puede manipular desde el navegador). Se buscan fallas de seguridad en el procesamiento de datos. El foco principal se colocará en las pruebas de control de acceso roto. Se analizará cómo el servidor web maneja las sesiones y si los identificadores de recursos (IDs de clientes o pedidos) son secuenciales y editables.

Explotación: evaluar que tan fácil es acceder. Se intenta replicar técnicamente el incidente reportado. El auditor modificará manualmente el ID del cliente o del pedido en las peticiones HTTP para comprobar si el sistema devuelve los datos de otra cuenta (IDOR/CWE-639).

Post-explotación: se mide el alcance del daño potencial. Si se logra explotar el fallo de control de accesos, se analiza si el nivel de privilegio comprometido permite escalar hacia funciones administrativas de la empresa (módulo de manejo de personal) o si expone datos de facturación e historial de compras de miles de clientes.

Informe: se redacta un documento profesional. Este contendrá un resumen ejecutivo para los directivos de Aurora Market, tablas con puntuaciones CVSS 4.0 para cuantificar el riesgo de manera objetiva, capturas de pantalla de la explotación controlada, y las recomendaciones específicas de remediación para su equipo de desarrollo.

Investigación

Metodología elegida: OWASP Web Security Testing Guide (WSTG) combinado con el estándar de ejecución PTES (Penetration Testing Execution Standard)

¿Por qué sería útil para este proyecto?:

La aplicación de Aurora Market es puramente web y maneja flujos lógicos complejos (compras, soporte, personal). WSTG ofrece una lista exhaustiva de escenarios de prueba diseñados específicamente para aplicaciones web, asegurando que no se pasen por alto brechas de seguridad críticas.

Incidente del reportado: "un usuario visualizó información de otra cuenta" apunta directamente a una falla de Control de Acceso Roto (OWASP A01:2021). La WSTG contiene guías de pruebas específicas para detectar referencias directas inseguras a objetos (IDOR) y fallas de autorización multifase.

Desarrollo de la estructura: el uso de PTES garantiza que el proyecto se ejecute de manera altamente estructurada (desde la definición segura de las reglas de compromiso hasta el proceso post-evaluación), protegiendo la integridad operativa de un comercio electrónico activo que no puede permitirse caídas de servicio.

Anexo técnico.

1. Logs de escaneos: datos textuales de puertos e identificación de tecnologías Apache/Nginx expuestas.

```
=====
[+] Objetivo Analizado: Plataforma E-commerce "Aurora Market"
[+] Técnica Aplicada: Descubrimiento de rutas y mapeo pasivo de endpoints
=====
RUTAS Y DIRECTORIOS IDENTIFICADOS:
• /index.php      -> Página principal del comercio
• /login          -> Portal de autenticación de usuarios
• /registro       -> Registro de cuentas de clientes
• /carrito        -> Módulo de compras y pagos
• /area-personal  -> Panel de control y perfil del usuario
• /api/v1/customers/ -> API de consulta de perfiles y PII
• /api/v1/orders/  -> [!] Endpoint de pedidos (Vulnerable a IDOR)
• /admin/backoffice -> Acceso restringido (Personal interno)

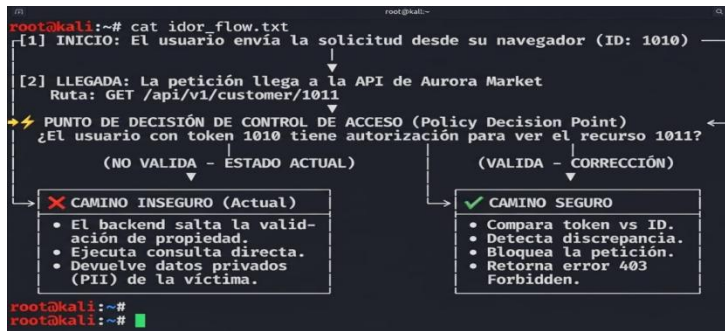
INVENTARIO TÉCNICO EXTERNO:
• Servidor Web: Apache / Nginx (Cabeceras expuestas)
• Cifrado: Certificado SSL/TLS activo
• Tipo de Base de Datos: Centralizada orientada a gestión de clientes
=====
```

2. Archivo de evidencias: capturas de pantalla e interceptaciones HTTP completas de la reproducción del fallo IDOR (W-001).

```
root@kali:~# curl -i -X GET 'http://api.example.com/customer/1011'
HTTP/1.1 200 OK
Date: Mon, 31 Aug 2026 10:45:30 GMT
Server: Apache/2.4.54 (Debian)
Content-Type: application/json
Content-Length: 175
Connection: keep-alive

{
  "customer_id": 1011,
  "full_name": "Aurora Pérez",
  "email": "aurora.perez@example.com",
  "shipping_address": "Mexico",
  "account_status": "active",
  "loyalty_tier": "Gold",
  "phone_number": "+52 55 1234 5678"
}
```

4. Diagrama de flujo: representación visual de los flujos de datos lógicos de acceso seguros versus inseguros.



5. Glosario: glosario de términos clave (PII, IDOR, CWE, CVSS, OWASP) para facilitar el entendimiento directivo.

Término / Abreviatura	Definición Técnica Aplicada al Informe
PII	Datos de Identificación Personal (Personally Identifiable Information). Información sensible de los clientes de Aurora Market Market (nombres, teléfonos, direcciones, correos).
IDOR	Referencia Directa Insegura a Objetos (Insecure Direct Object Reference). Vulnerabilidad de control de acceso donde se exponen recursos ajenos al alterar un parámetro en la ruta web.
CWE-862 / CWE-863	Ausencia de Autorización (Missing / Incorrect Authorization). Clasificación estándar que indica la falta de validación de permisos en el lado del servidor.
CVSS	Sistema Común de Puntuación de Vulnerabilidades (Common Vulnerability Scoring System). Estándar métrico para calcular y priorizar la gravedad del riesgo de manera cuantitativa.

6. Puntuación cualitativa del riesgo (CVSS)

ID	Título del Hallazgo	Activo Afectado	Severidad	CVSS 4.0.	Vector	Mapeo CWE	Mapeo OWASP
W-001	Control de Acceso Roto: Referencia Directa Insegura a Objetos (IDOR)	API de Consulta de Clientes / Historial	Alta	8.7	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	CWE-862 CWE-863	A01:2025-Control de acceso defectuoso